

ACCESS CONTROL POLICY

Version 1.0

Revision Date: August 18, 2026

Contact: security@prompthalo.com



DOCUMENT INFORMATION

Document Family	Governance, Ethics, and Security
Document Title	Access Control Policy
Document ID	POL-AC-001
Current Version	1.0
Approved Date	August 18, 2026
Approved By	Information Security Steering Committee
Effective Date	August 18, 2026
Next Review Date	August 18, 2027
Classification	Internal
Document Owner	Chief Executive Officer — Accountable Party
Prepared By	Security Officer
Review Cycle	Annual, or upon material change
Supersedes	N/A
Audience	All personnel, including employees and contractors

APPROVERS AND OWNERS

Name	Role	Information Security Role	Signature	Date
Madhuri Chandoor	Approver	CEO and Founder		August 18, 2026
Praveen Sharma	Owner / Author	Fractional CISO/Security Officer		August 18, 2026

COMPLIANCE

This Policy is authorized by the Information Security Policy (POL-ISP-001) and supports the SOC 2 Trust Services Criteria CC1.4, CC4.1, CC5.2, CC6.1, CC6.2 and CC6.3, HIPAA Security Rule 45 CFR §164.308(a)(3) and §164.308(a)(4), and GDPR Article 32. It is written for a remote, largely fractional team working in AWS, GitHub and Google Workspace from their own laptops.

DOCUMENT VALIDITY

This document is valid only in its published electronic form in the PromptHalo Technologies policy repository. Printed or locally saved copies are uncontrolled and must be verified against the published version before use. This document is classified Internal and may not be distributed outside PromptHalo Technologies or its authorized clients without the written approval of the Security Officer.

TABLE OF CONTENTS

1 OVERVIEW AND PURPOSE5

2 SCOPE5

3 ROLES AND DEFINITIONS.....5

4 TERMINOLOGY5

5 HOW ACCESS IS GRANTED6

6 PRIVILEGED AND NON-HUMAN ACCESS.....7

7 ACCESS TO CLIENT SYSTEMS.....7

8 JOINERS, MOVERS AND LEAVERS7

9 ACCESS REVIEWS.....8

10 RECORDS8

11 EXCEPTIONS.....8

12 REFERENCE8

13 DOCUMENT POLICY HISTORY.....9

1 Overview and Purpose

Access is where most of what SOC 2 tests lives: who can reach what, how they got it, and how it goes away. PromptHalo Technologies (“the Company”) is a small remote team in AWS, GitHub and Google Workspace, and this Policy sets access on that basis.

Two things carry the risk: access granted without a record, and access that outlives the reason for it. Everything below serves one of those two.

2 Scope

This Policy applies to access to Company systems — Google Workspace, AWS, GitHub, the password manager and any other account the Company holds data in — and to access the Company holds inside client environments.

It covers people and non-human identities alike: service accounts, automations and agents. It does not reach a person's own device, which is addressed in the Acceptable Use Policy.

3 Roles and Definitions

1. "The Company" refers to PromptHalo Technologies.
2. The CEO or, in their absence, the Security Officer (the “Accountable Party”) owns this policy, oversees its implementation and enforcement, and may delegate specific duties to a designee. [SOC 2: CC1.3]
3. The Information Security Steering Committee approves this policy and reviews it at least annually. [SOC 2: CC1.2, CC5.3]
4. The Accountable Party approves access to production, customer data and administrative functions. Where the Accountable Party is also the requester, the CEO confirms the grant instead and the confirmation is recorded — at this size the same person will sometimes be both, and recording it is the answer. [SOC 2: CC6.3, CC5.2]
5. Every non-human identity has a named human owner. [SOC 2: CC6.3]

4 Terminology

The following terms have the meanings given below wherever they appear in this policy.

1. **Accountable Party** — the CEO or, in their absence, the Security Officer, who owns this policy.
2. **Break-glass credential** — an emergency credential held for use when normal access fails, kept under hardware multi-factor authentication.
3. **Confidential information** — information classified Confidential or Restricted under the Data Classification Policy, including customer data.
4. **Control** — an activity, automated or manual, performed on a defined cadence that produces evidence it occurred.

5. **Deficiency** — a control that is absent, not operating as described, or not producing evidence.
6. **Identity provider** — Google Workspace, through which people authenticate to Company systems.
7. **Information Security Steering Committee** — the Company's oversight body for information security. At the Company's current size, the Committee comprises the CEO, and every reference in this policy to a decision, approval, review or report of the Committee is satisfied by a dated written record made or confirmed by the CEO; a formal meeting is not required. [SOC 2: CC1.2, CC1.3]
8. **Non-human identity** — a service account, automation or agent that acts on Company systems under its own credentials.
9. **Personnel** — employees, officers, contractors, consultants, interns and temporary workers of the Company.
10. **Privileged access** — administrative access to production, to customer data, or to the identity provider.
11. **Security Officer** — the individual accountable for day-to-day operation of the security program.
12. **Significant change** — a change meeting the trigger criteria in the Risk Management Policy that requires risk reassessment.
13. **Subservice organization** — a third party whose controls the Company relies upon and which is carved out of the Company's report.

5 How Access Is Granted

1. Access is denied by default and granted on least privilege to a named individual identity. Shared logins are not used. [SOC 2: CC6.1]
2. Access is requested and approved before it is granted, and the record shows who asked, who approved, what was granted and when. An email thread is a sufficient record; a ticketing system is not required. [SOC 2: CC6.2 · HIPAA §164.308(a)(4)]
3. New people get a defined baseline for their role rather than a copy of someone else's access. Copied access carries entitlements nobody has reviewed, and it is how privilege accumulates quietly. [SOC 2: CC6.2]
4. Screening is completed and recorded before access to production systems or customer data is granted, under the Screening Standard. [SOC 2: CC1.4 · HIPAA §164.308(a)(3)]
5. People authenticate through Google Workspace, and applications use single sign-on wherever they support it, so that one suspension at departure removes access in most places at once. [SOC 2: CC6.1]

6 Privileged and Non-Human Access

1. Privileged access is granted only where the role requires it, approved separately, and held apart from the day-to-day account where the platform allows. [SOC 2: CC6.3]
2. Break-glass credentials are held in the password manager under hardware multi-factor authentication, their use raises an alert, and each use is recorded with the reason. [SOC 2: CC6.3, CC7.2]
3. Non-human identities — service accounts, automations and agents — are inventoried with a named human owner, their purpose, what they can reach, and how their credentials are held. They are reviewed alongside people. [SOC 2: CC6.3, CC2.1]
4. Production and non-production are separated at the cloud account boundary, with permission sets granting only what a role needs in each. The configuration is in the Cloud Platform Standard. [SOC 2: CC5.2]
5. Segregation of duties is applied where practicable. Where the Company's size prevents it, the compensating control is named in the Annual Control Environment Assessment rather than left unstated. [SOC 2: CC5.2, CC1.3]

7 Access to Client Systems

1. Access the Company holds inside a client environment is granted only under the engagement agreement, limited to the scope authorized, and given up when the engagement ends. [SOC 2: CC6.3 • C1.1]
2. Standing access to a client estate is the Company's largest insider risk and is reviewed at the monthly sitting under the Logging and Monitoring Policy, not only at the quarterly review. [SOC 2: CC6.3, CC3.3]

8 Joiners, Movers and Leavers

1. Access changes with the role. A person moving to different work has access adjusted, not accumulated — the mover case is the one most often missed. [SOC 2: CC6.2]
2. Access is revoked within one business day of departure, and immediately where the departure is involuntary. The Google Workspace suspension timestamp is the evidence. [SOC 2: CC6.2 • HIPAA §164.308(a)(3)(ii)(C)]
3. Access that does not run through single sign-on is listed by name on the offboarding checklist and removed one by one — AWS, GitHub, shared credentials in the password manager, and any third-party AI service. [SOC 2: CC6.2, CC6.3]
4. Contractor identities carry an engagement end date so access lapses if the engagement is not renewed. Most of the Company is engaged this way, so this is the ordinary path. [SOC 2: CC6.2]
5. A complete joiner, mover and leaver population for the period is retained, so that the reviews below have a denominator. [SOC 2: CC6.2, CC2.1]

9 Access Reviews

This is the control most likely to fail on timing rather than design. Four occurrences are needed in a twelve-month period, and a missed quarter cannot be recreated afterwards.

1. Access to systems within the audit boundary is reviewed quarterly or yearly, as applicable, to confirm that access remains appropriate. Any necessary changes or removals are documented. [SOC 2: CC6.3, CC4.1]
2. Removals identified by a review are actioned and the action recorded. A review that identifies removals and does not complete them is worse evidence than no review, because it shows the Company knew. [SOC 2: CC6.3]
3. Non-human identities and client-environment access are included in the same review rather than handled separately. [SOC 2: CC6.3]
4. An export from each platform on the review date, with decisions recorded against it, is a sufficient record. At this size the whole review is an hour. [SOC 2: CC4.1, CC6.3]

10 Records

1. Access requests and approvals, including CEO confirmations where the approver was the requester. [SOC 2: CC6.2]
2. Four quarterly access review records a year, with populations and decisions. [SOC 2: CC6.3, CC4.1]
3. The joiner, mover and leaver population for the period. [SOC 2: CC6.2]
4. The non-human identity inventory with owners. [SOC 2: CC6.3]
5. Break-glass use records. [SOC 2: CC6.3]

11 Exceptions

Where a requirement of this Policy cannot be met — an application that does not support single sign-on, or a platform without separate privileged accounts — the position is recorded by the Accountable Party with the compensating measure and a review date. Where no exceptions are in force, that is recorded affirmatively at the annual review.

12 Reference

1. SOC 2 Trust Services Criteria, Security category [CC1.4, CC4.1, CC5.2, CC6.1, CC6.2, CC6.3]
2. POL-ISP-001 Information Security Policy [SOC 2: CC5.3]
3. STD-SCR-001 Screening Standard [SOC 2: CC1.4]
4. STD-CLD-001 Cloud Platform Standard [SOC 2: CC5.2, CC6.1]
5. POL-LOG-001 Logging and Monitoring Policy [SOC 2: CC7.2]
6. POL-HRS-001 Human Resources Security Policy [SOC 2: CC6.2]

- 7. POL-PWD-001 Password and Authentication Policy [SOC 2: CC6.1]
- 8. FRM-CE-001 Annual Control Environment Assessment [SOC 2: CC5.2]
- 9. HIPAA Security Rule, 45 CFR §164.308(a)(3) and §164.308(a)(4)
- 10. EU General Data Protection Regulation, Article 32

13 Document Policy History

Version	Date	Description
1.0	August 18, 2026	Initial policy release